



Internet



Block List

Roteador de Borda

Implementar um roteador de borda para filtrar pacotes maliciosos

- Inspeção de pacotes (SPI)
- criptografia de comunicação (VPN + MFA) para autenticação na caixa apenas,
- controle de acesso (WPA3)
- mensurar tempo de reboot, de patches update

NG Firewall

Implementar um NG Firewall para bloquear acessos dos usuários indevidos no ambiente

Para Proteção de Autenticação

- Para proteção de acesso
- Listas de ACL
- LDAP/RADIUS (Jogar pra autenticação local - Data Domain) -> consome recursos do roteador
- 802.1X
- IPS/IDS: Detecção e prevenção de intrusão baseada em assinaturas e anomalias;
- Control application

CDN &

Implementar u distribuir carga

- Ocultação de borda seja exp
- Caching Estr
- internos servir
- Anycast Netw
- mitigar latênci



Network Protection

NG Firewall

Implementar um NG Firewall para bloquear acesso de sites específicos, protocolos e portas também. Sendo esta uma primeira barreira

Proteção

- Proxy de Acesso ao sistema
- DPI (inspeção de pacotes) -> dinamica a partir do CTI
- VPN + MFA
- SPI (Stateful Packet Inspection): Monitoramento do estado das conexões ativas;
- Hardening de Gerenciamento: Acesso à interface de configuração apenas via VPN + MFA;

WAF

Garantir a segurança dos serviços presentes no ambiente, garantindo resistencia a ataques sofisticados

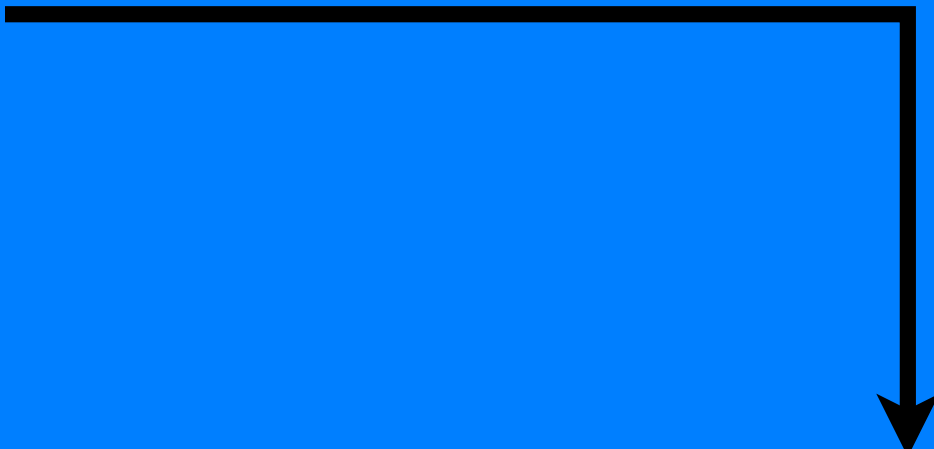
Importante:

- filtragem de trafego HTTP;HTTPS
- bloqueio de ameaças OWASP TOP 10
- gerenciamento de presença de BOTs;
- mitigação de DDoS
- segurança de APIs
- Analise COmportamental com IA;
- Serviços de Identidade: Integração com LDAP/RADIUS para aplicar políticas baseadas no usuário (Identity-Aware).





	DDOS Mitigation & Scrubbing
Edge Protection uma rede de entrega de conteúdo para a e mascarar o IP real da infraestrutura. de Origem: Impedir que o IP do roteador de posto publicamente; ratégico: Reduzir a carga nos servidores ndo conteúdo estático na borda; work: Distribuir o tráfego globalmente para a e ataques volumétricos.	Filtragem de tráfego em larga escala para garantir a disponibilidade, Este aqui estaria atrelado ao Firewall. Importante: - Mitigação de Camada 3, 4 e 7: Bloqueio de ataques de inundação (SYN, UDP flood) e ataques de exaustão de recursos HTTP; - Reputação de IP Global: Bloqueio automático de IPs conhecidos por botnets antes de atingirem a rede local.



Monitoramento

SIEM

Implementado para centralizar os eventos e dar capilaridade na detecção do que está ocorrendo

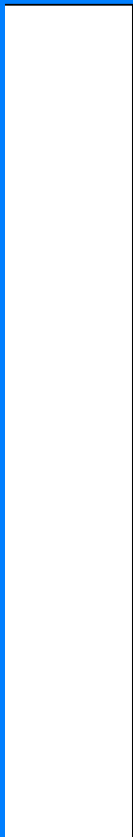
Centralização de Logs (Log Management): Coletar eventos do Roteador, NGFW, WAF, Bancos de Dados e Cloudflare em um único local;

- Correlação de Eventos: Identificar que um erro de login no Banco de Dados (Data Domain) está relacionado a um tráfego suspeito detectado pelo WAF minutos antes;
- Dashboard de Conformidade: Gerar relatórios automáticos para auditorias de conformidade (NIST, ISO 27001);
- Retenção de Dados: Armazenamento histórico de logs para perícia digital (Forensics) após um incidente.

EDR/XDR

Esta funcionalidade deve ser adicionada com foco em Clients e VMs/Servidores.

- Monitoramento de Processos: Registro de cada execução de binários, scripts e comandos (Powershell, Bash) para detectar anomalias;
- Análise de Árvore de Processos: Identificar se um processo legítimo (como o Word ou um Navegador) gerou um processo suspeito (como um terminal);
 - Isolamento de Host: Capacidade de "cortar" a rede do dispositivo infectado remotamente para conter um surto de malware;
 - Remediação: Rollback de alterações feitas por ransomware ou remoção automática de persistências no registro/arquivos;
 - Visibilidade Transversal: Unificar a visão do que acontece no "Client" com o que o "WAF" e o "CDN" estão vendo;
 - Resposta Orquestrada: Se o XDR detecta um ataque no servidor Python (Uvicorn), ele pode automaticamente instruir o Firewall de Borda a bloquear o IP do atacante;
 - Threat Hunting: Ferramentas de busca proativa por ameaças baseadas em IOCs (Indicadores de Comprometimento) globais.



Data Domain

VMs

Kubernetes -> Docker

Implementar virtualização para serviços específicos, aplicações de uso interno/externo, organização dos ambientes de desenvolvimento e de produção.

Proteção:

- servidores guest devidamente hardenizados
- portas abertas estritamente necessárias,
- serviços rodando apenas sendo os necessários,
- não permitir root over ssh
- acesso remoto apenas criptografado e com par de chaves,
- containers em redes apartadas
- configuração de redundância nos Pods para balanceamento de carga;

Complementar com SIEM e XDRs

VMs e Containers

Implementar virtualização segura e orquestração

Proteção:

- Hardening de Host/Guest: Configuração de SO (minimal) e desativação de serviços desnecessários
- Segurança de Acesso: Proibição de login de root e autenticação exclusiva por par de chaves;
- Isolamento de Rede: Containers operando em redes apartadas (Micro-segmentação);
- Alta Disponibilidade: Configuração de redundância e balanceamento de carga nativo;
- Sensores de SIEMs/XDRs

Enterprise Components

Servidores

Servidores on premise conectados à rede, servindo de redundância e também para disponibilizar serviços específicos.

- LDAP e RBAC -> com foco em permitir autenticação dos usuários ao sistema,
- VPN -> para tunelar o tráfego externo;
- Modelo AAA -> para garantir a integridade do ambiente, assim como disponibilizar recursos de auditoria
- Sensores para SIEMs e XDRs

Databases

Dados

Considerando a mesma visão dos servidores, mas com proteção e camada de persistência de dados.

- RBAC (Role-Based Access Control): Acesso estritamente limitado por função de usuário/aplicação;
- Criptografia em Repouso (At-Rest): Garantir que os dados no disco estejam cifrados
- Auditoria de Consultas (AAA): Logs detalhados de quem acessou o dado e quando (Audit Trail);
- DLP (Data Loss Prevention) para evitar perda de dados, com bloqueio na transferência de dados e monitoramento de tráfego de dados;
- Sensores de SIEM e XDRs

Clients

Estações

Inserção de agentes/sensores que permitam monitorar dados, processos e demais elementos do ambiente.

- Gestão de Identidade e Acesso (IAM - Zero Trust):
- MFA Obrigatório;
- Criptografia de Disco;
- NAC (Network Access Control - 802.1X) para garantir que apenas dispositivos com certificados digitais válidos e conformidade de segurança (patching em dia, EDR ativo) possam se conectar à rede;
- MDM / UEM (Unified Endpoint Management): Garantir que o sistema operacional esteja atualizado e com as configurações de segurança (GPOs) aplicadas antes de permitir o acesso ao Data Domain;
- Sensores de SIEM e XDR:

o resiliente.

enxuto
rios;
ot via SSH e
redes virtuais
ncia em Pods

da
to por
sco
u qual
oqueio



